

The Open Group Snapshot

Security Roles and Glossary

Part 2: Roles Implementation



NOTICE

Snapshot documents are draft standards, which provide a mechanism for The Open Group to disseminate information on its current direction and thinking to an interested audience, in advance of formal publication, with a view to soliciting feedback and comment.

A Snapshot document represents the interim results of an activity to develop a standard. Although at the time of publication The Open Group intends to progress the activity towards publication of a Preliminary Standard or (full) Standard of The Open Group, The Open Group is a consensus organization, and makes no commitment regarding publication. Similarly, a Snapshot document does not represent any commitment by any member of The Open Group to make any specific products available.

This Snapshot document is intended to make public the direction and thinking about the path we are taking in the development of Security Roles and Glossary Standard, Part 2: Roles Implementation. We invite your feedback and guidance. To provide feedback on this Snapshot document, please send comments by email to ogspecs-snapshot-feedback@opengroup.org no later than May 31, 2026.

This Snapshot document is valid through May 31, 2026, only.

For information on joining the Security Forum, please send email to www.opengroup.org/join-forum.

Copyright © 2025, The Open Group

No part of this publication may be reproduced, stored in a retrieval system, distributed, displayed, or transmitted in any form or by any means, including photocopying, recording, or other electronic or mechanical methods, without the prior written permission of the copyright owners. Specifically, without such written permission, the use or incorporation of this publication, in whole or in part, is NOT PERMITTED for the purposes of training or developing large language models (LLMs) or any other generative artificial intelligence systems, or otherwise for the purposes of using, or in connection with the use of, such technologies, tools, or models to generate any data or content and/or to synthesize or combine with any other data or content.

It is fair use of this specification for implementors to use the names, labels, etc. contained within the specification. The intent of publication of the specification is to encourage implementations of the specification.

This specification has not been verified for avoidance of possible third-party proprietary rights. In implementing this specification, usual procedures to ensure the respect of possible third-party intellectual property rights should be followed.

Any use of this publication for commercial purposes is subject to the terms of the Annual Commercial License relating to it. For further information, see www.opengroup.org/legal/licensing.

The Open Group Snapshot

Security Roles and Glossary – Part 2: Roles Implementation

Document Number: S253

Published by The Open Group, November 2025.

Comments relating to the material contained in this document may be submitted to:

The Open Group, Apex Plaza, Forbury Road, Reading, Berkshire, RG1 1AX, United Kingdom
or by electronic mail to:

ogspecs@opengroup.org

Contents

1	Introduction	1
1.1	Objective	1
1.2	Overview	1
2	Introduction to Organizational Roles and Functions	2
2.1	Core Truth of Security Universality.....	2
2.1.1	Security is Part of Everyone’s Job	2
2.1.2	Security is a Team Sport	3
2.2	Accountabilities and Responsibilities	5
2.2.1	Accountability and Responsibility Model Tenets	6
2.2.2	Security Risk Outcomes	7
2.2.3	Security Risk Council and Individual Accountability.....	9
3	Role Definition Structure and Terminology.....	10
3.1	Key Information for Each Role	10
3.2	Role Terminology	10
4	Assigning and Managing Security Accountability and Responsibility.....	12
4.1	Security Accountabilities, Responsibilities, and Job Functions	12
4.1.1	Security Accountabilities	12
4.1.2	Security Responsibilities	13
4.2	Types of Roles	13
4.2.1	Non-Security Roles with Security Accountabilities.....	14
4.2.2	Security Roles with Security Responsibilities	15
4.2.3	Dual-Purpose Security and Enablement Roles	15
4.3	Collaboration between Security and Non-Security Roles	16
4.3.1	Duties of Security Decision-Making.....	17
4.4	Relationships between Accountable and Responsible Parties	18
4.4.1	Factors Driving and Determining the Collaborative Process.....	18
4.4.2	Dealing with Complexity and Fluidity in the Collaborative Process	19
4.5	General Security Impacts	20
5	Adapting and Adopting Role Guidance	22
5.1	Adapting Role Guidance	22
5.2	Adopting Role Guidance	22
5.2.1	Adoption Strategy for Non-Security Roles.....	22
5.2.2	Adoption Strategy for Security Roles (Responsibilities)	23

Preface

The Open Group

The Open Group is a global consortium that enables the achievement of business objectives through technology standards and open source initiatives by fostering a culture of collaboration, inclusivity, and mutual respect among our diverse group of 900+ memberships. Our membership includes customers, systems and solutions suppliers, tool vendors, integrators, academics, and consultants across multiple industries.

The mission of The Open Group is to drive the creation of Boundaryless Information Flow™ achieved by:

- Working with customers to capture, understand, and address current and emerging requirements, establish policies, and share best practices
- Working with suppliers, consortia, and standards bodies to develop consensus and facilitate interoperability, to evolve and integrate specifications and open source technologies
- Offering a comprehensive set of services to enhance the operational efficiency of consortia
- Developing and operating the industry's premier certification service and encouraging procurement of certified products

Further information on The Open Group is available at www.opengroup.org.

The Open Group publishes a wide range of technical documentation, most of which is focused on development of Standards and Guides, but which also includes white papers, technical studies, certification and testing documentation, and business titles. Full details are available at www.opengroup.org/library.

The Security Roles and Glossary Snapshot

The Security Roles and Glossary Standard is a Snapshot being developed by The Open Group. The standard defines consistent terminology, roles, and security accountabilities and responsibilities that an organization may adopt. It consists of three parts:

- Part 1: Introduction and Definitions
- Part 2: Roles Implementation (this document)
- Parts 3.X: Role Definitions
 - Part 3.1: Roles and Accountabilities for Organization Leaders and Governance
 - Part 3.2: Roles and Responsibilities for Security Operations (SecOps/SOC)

The division of the standard into separate parts allows each part to be updated and re-versioned as required as we move forward with the Security Roles and Glossary Standard.

This Document

This is a Snapshot document of what is intended to become the Security Roles and Glossary Standard – Part 2: Roles Implementation. It is being developed by The Open Group.

For the normative references, conformance requirements, and terminology applicable to this document, refer to Part 1 [S252].

This document, Part 2, provides a single clear model of role responsibilities and accountabilities that has been reconciled against a complete model of an organization, the imperatives for effective security risk management, and the security capabilities needed to execute on it.

Parts 3.X provide detailed descriptions of roles and their respective responsibilities and accountabilities.

Roles guidance: The collective set of roles guidance (Part 2 and Parts 3.X) is designed to aid in all aspects of security including but not limited to:

- Security organizational planning for business, technology, and security roles including assignment of security risk accountabilities and goals (from the Board of Directors to technology specialists)
- Security education and awareness planning across all roles in an organization
- Building job roles and job descriptions for security roles and augmenting descriptions for non-security roles
- Evaluating candidates during the hiring process
- Evaluating performance against job requirements and outcomes
- Career planning for individuals (technical, leadership, architecture, etc.) and managers coaching their team
- Planning and managing outsourcing of security functions and roles (including identifying what to evaluate, how to structure management of the outsourced function, and evaluating outsourcer competency and performance)

Trademarks

ArchiMate, FACE, FACE logo, Future Airborne Capability Environment, Making Standards Work, Open Footprint, Open O logo, Open O and Check certification logo, Open Subsurface Data Universe, OSDU, Sensor Open Systems Architecture, SOSA, SOSA logo, The Open Group, TOGAF, UNIX, UNIXWARE, and X logo are registered trademarks and Boundaryless Information Flow, Build with Integrity Buy with Confidence, Commercial Aviation Reference Architecture, Dependability Through Assuredness, Digital Practitioner Body of Knowledge, DPBoK, Eagle AI Assistant and logo, EMMM, FHIM Profile Builder, FHIM logo, FPB, Industrial Advanced Nuclear, IT4IT, IT4IT logo, O-AA, O-DA, O-DEF, O-HERA, O-PAS, O-TTPS, O-VBA, Open Agile Architecture, Open Digital Transformation, Open FAIR, Open Process Automation, Open Trusted Technology Provider, and Sensor Integration Simplified are trademarks of The Open Group.

All other brands, company, and product names are used for identification purposes only and may be trademarks that are the sole property of their respective owners.

Acknowledgements

(Please note affiliations were current at the time of approval.)

The Open Group gratefully acknowledges the contribution of the following people in the development of this document:

- Mark Simos, Microsoft
- Nikhil Kumar, Applied Technology Solutions, Inc.

Additional contributors:

- Tony Carrato, The Open Group Invited Expert
- Steve Faehl, Microsoft
- Ian Leatherman, Microsoft
- John Linford, The Open Group Security Portfolio Director
- Tim Morrow, Carnegie Mellon University SEI
- Tom Quinn, formerly of Microsoft
- Antony Selim, RTX
- Hasan Yasar, Carnegie Mellon University SEI

Referenced Documents

The following documents are referenced in this standard.

(Please note that the links below are good at the time of writing but cannot be guaranteed for the future.)

- [C247] Zero Trust Commandments, a standard of The Open Group (C247), published by The Open Group, August 2024; refer to: www.opengroup.org/library/c247
- [C251] The Open Group Standard for Risk Taxonomy (O-RT), Version 3.1, a standard of The Open Group (C251), published by The Open Group, May 2025; refer to: www.opengroup.org/library/c251
- [NIST CSF] NIST Cybersecurity Framework (CSF) 2.0, published by National Institute of Standards and Technology, February 2024; refer to: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- [S232] Zero Trust Reference Model Snapshot (S232), published by The Open Group, October 2023; refer to: www.opengroup.org/library/s232
- [Simos & Kumar, 2023] Zero Trust Overview and Playbook Introduction: Guidance for Business, Security, and Technology Leaders and Practitioners, by Mark Simos and Nikhil Kumar, published by Packt Publishing, October 2023
- [S252] Security Roles and Glossary Snapshot – Part 1: Introduction and Definitions, The Open Group Snapshot (S252), published by The Open Group, November 2025; refer to: www.opengroup.org/library/s252

1 Introduction

1.1 Objective

This document is a Snapshot of the Security Roles and Glossary Standard – Part 2: Roles Implementation. The objective of Part 2 is to describe security responsibilities and accountabilities for all roles in an organization across business, technology, and security teams.

This Snapshot document is intended to make public the direction and current approach being taken in the development of the Security Roles and Glossary Standard – Part 2: Roles Implementation. We invite your feedback and guidance. To provide feedback on this Snapshot document, please send comments by email to ogspecs-snapshot-feedback@opengroup.org no later than May 31, 2026.

1.2 Overview

This Snapshot document presents a proposal for a standard that defines how to effectively assign security accountability and responsibility in an organization to achieve effective security. Just like a physical business operations require door locks and other physical security, a digital business requires effective security to exist and operate. This guidance supports and enables a Zero Trust approach to security.

2 Introduction to Organizational Roles and Functions

This document, Part 2, describes how to correctly structure and implement security accountabilities and responsibilities for all roles in an organization across business, technology, and security teams.

Adapt these to your organization – the contents of these roles will need to be adapted to each organization, as job titles and functions will vary across organizations. The accountabilities and responsibilities defined in this document (also referred to as job functions) allow that adaptation and mapping.

Organizations may assign job functions from one or more roles to an individual and should plan on evolving those assignments as the organization evolves its structure, domain of operation, size, etc.

2.1 Core Truth of Security Universality

This document recognizes an important universal truth: *Organizational security risk may be created or amplified by any decision or action by any organizational employee, partner, or supplier.*

This leads to two key implications that must be recognized for every organization:

1. **Security is everyone's job** – no roles exist without any security responsibilities or accountabilities
2. **Security is a team sport** – managing security risk effectively requires roles to work collaboratively with each other

2.1.1 Security is Part of Everyone's Job

Effective security risk management requires every role in an organization to actively support security objectives and have security literacy for their role. This includes all roles in the organization, from the Board of Directors and business leaders to highly technical engineers, as well as all information workers and frontline workers. While every role is not dedicated to security, all roles have a critical part to play in keeping the organization safe and helping manage this risk.

All roles must recognize that security has fiduciary and risk implications, impacts business in terms of capability and execution, and impacts all technology and technology usage in the organization. All individuals also must recognize that their involvement is crucial in the execution of the organization's security posture, and is their duty.

In this respect, security risk is similar to specialized disciplines like legal, finance, physical safety, and Human Resources (HR): Anyone in the organization can create or amplify organizational risk from these specialized areas, so everyone in the organization must apply these to their daily roles; everyone must have a basic literacy of the specialized discipline.

2.1.1.1 No Roles Exist without Any Security Responsibilities or Accountabilities

There are no roles without any security responsibilities or accountability in most organizations. While such a role could conceivably be designed, the practical reality is that any useful role in an organization is trusted to perform tasks on behalf of the organization (even a temporary summer

intern that performs simple business processes or reviews business/customer information). Any role could cause a security issue through mistakes in executing their role or by performing activities beyond their role scope (such as a malicious insider working on behalf of an external threat actor).

Each role in the organization supports management of security in a unique way specific to that role, though there are common elements across many roles (described later in this document).

This document defines common roles for most functions, and also recognizes that the core business operations and roles of an organization will vary significantly based on industry and unique mission of the organization. The information worker/frontline worker role definition describes the common security responsibilities that must be adapted to the specific roles in your organization, such as nurses, doctors, truck drivers, retail sales representatives, petroleum engineers, actors, musicians, stockbrokers, account managers, market analysts, and manufacturing line technicians.

2.1.2 Security is a Team Sport

The tasks required for effective security management often require combining specialized expertise and skills from many stakeholders across business, technology, and security teams.

Roles across the organization must collaborate with each other on security risk to manage security risk effectively – organizations are complex entities composed of people, processes and technologies, and *security decisions often require the expertise of multiple people* with different specialized skills and knowledge.

For example, multiple sets of expertise are required to find and correct a security risk in a complex business process in which an attacker may impersonate a trusted partner to get access to business assets, including:

- *Security professionals* who understand attacker motivations and methods
- *Business operations personnel* who operate the process daily
- *Technology experts* who understand the technical systems and their constraints
- *Legal professionals* who understand the potential contractual, regulatory, and criminal implications of a change
- *Business leaders* who are accountable for the business outcomes and contracts
- *Vendors* who must agree to any changes

Collaboration is required across all stages of the security lifecycle (derived from the *NIST Cybersecurity Framework (CSF) 2.0* [[NIST CSF](#)]) to effectively:

- **Identify** assets and potential vulnerabilities in a system or process
- **Prevent** exploitation of vulnerabilities with changes
- **Detect** anomalous activity in a system or process which may be part of an attack or other abuse
- **Respond** to an active attack or other anomalous event
- **Recover** from an attack, including performing root analysis to understand what went wrong and what can be done to prevent or mitigate future instances
- **Govern** controls across business, technology, and security teams

Tip: *Working together on security is often new to many stakeholders.*

These stakeholders may have never worked together (or may not have worked together in a long time), may not know each other's roles exist, may have never looked at individual systems as an interconnected whole, or may have never performed critical thinking and analysis on the system to see how it could go wrong before.

Many systems were built and successfully operated for many years in a fragile security state because nobody asked, "How can an attacker exploit this?", which is a foundational question behind the mindset for securing digital assets.

2.1.2.1 *Integrate Security into Normal Operations*

The execution of security tasks must be integrated into the normal processes of the organization including the architecture, design, implementation, and operations/management of systems. Security risk management will not be successful if it is "outsourced" to the security team and ignored or deprioritized within normal business operations. Even a well-funded "shadow" function within a security team (architecture, engineering, etc.) will fail if their work is not integrated with normal business operations.

These failures happen because the security team lacks the business and technology context (e.g., this security change would break critical business functionality), the business and technology team deprioritize security changes (causing the security risk to remain and/or grow), or both.

A modern Zero Trust approach to security requires integration of business, technology, and security teams. This model (described in this document) necessitates a cooperative and complementary relationship:

- **Security** teams must provide subject matter expertise on threats, mitigations, and security best practices (and lead incident response and related operational roles)
- **Business** decision-makers must own the determination and acceptance of business risk, including accountability for security risk outcomes of their decisions
- **Technology** stakeholders must integrate and implement security controls into the operation of technical systems and product delivery

Figure 1 illustrates this concept.

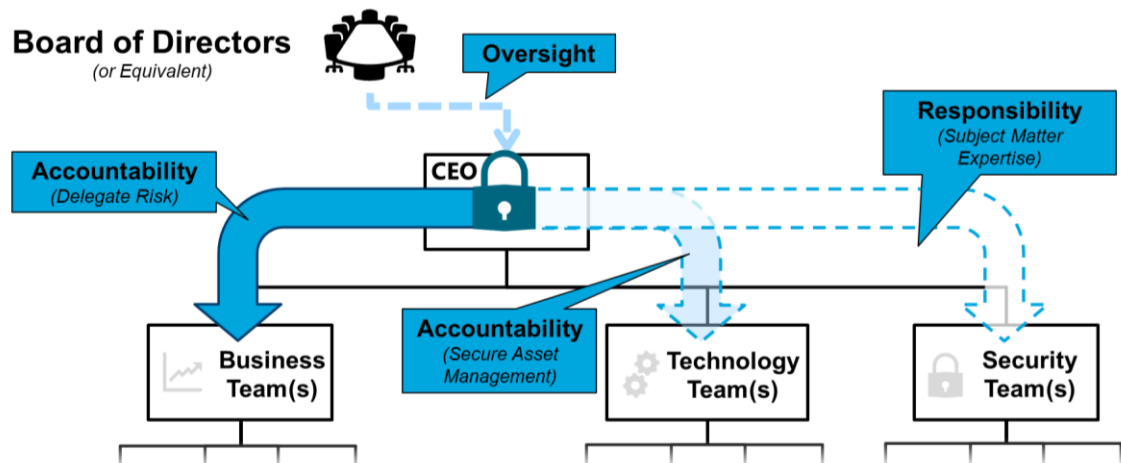


Figure 1: Security Accountability and Responsibility Delegation

Security tasks must be integrated correctly into business processes, and security duties must be executed faithfully by all roles as a normal part of business requirements. Doing this requires clearly and correctly defining security accountabilities and responsibilities across the organization.

2.2 Accountabilities and Responsibilities

Figure 2 illustrates the full range of roles that have security accountabilities and responsibilities. Each of these roles has a unique and specific contribution to managing and reducing the security risk of the organization.



Figure 2: Roles with Security Accountabilities and Responsibilities across the Organization

The roles in this figure are detailed throughout the Part 3.X documents.

Note: Most of these are standard roles across organizations in any industry. The information worker/frontline worker (marked with a star in Figure 2) represent the roles that are specific to your organization or industry, such as nurses, doctors, truck drivers, retail sales representatives, petroleum engineers, actors, musicians, stockbrokers, account managers, market analysts, and manufacturing line technicians.

The accountabilities and responsibilities in this document implement a distributed accountability model that ensures anyone making decisions that impact security risk can do so in an informed way that considers and effectively balances business goals and security risk.

2.2.1 Accountability and Responsibility Model Tenets

To drive a consistent model across the organization, the accountability and responsibility model in this document follows these tenets:

1. Security accountability is assigned to decision-makers
2. Decision-makers have access to specialized security expertise and advice
3. Technology team is engaged throughout the process to assess impact and implement decisions
4. Security experts perform specialized security tasks
5. Teamwork on security is required, recognized, and rewarded

2.2.1.1 Security Accountability is Assigned to Decision-Makers

People who make decisions that impact security risk in the course of their daily job are held accountable for that impact (from the top to the bottom of the organizational chart).

This is similar to how every role is held accountable for financial, legal, and other impacts. Security failures can have long-running impacts, and this must be recognized.

This accountability must be tied to incentive structures and other consequences to ensure appropriate focus and to prevent neglect.

2.2.1.2 Decision-Makers have Access to Specialized Security Expertise and Advice

Security Subject Matter Experts (SMEs) are responsible for providing decision-makers with sound advice that is tailored to the business context and decisions to be made.

SMEs are not accountable for decisions, but they should be held responsible for providing sound advice and context to enable good decisions. Clear assignment and documentation of responsibilities to roles allows organizations to identify the relevant SMEs.

2.2.1.3 Technology Team is Engaged throughout the Process to Assess Impact and Implement Decisions

Technology team members are responsible for assessing the impact and feasibility of all decisions on the technical estate, and are accountable for effective and complete implementation of security requirements in technology systems, processes, technology team security skills and readiness, and daily operations.

Technology team members implement the vast majority of security controls and must work with security experts and decision-makers to advise on feasibility, impact, and other aspects of security decisions and actions. Security requirements drive a significant percentage of technology strategy and execution, so close collaboration is critical. Technology teams work across both prevention (“left of bang”¹) and response/recovery (“right of bang”) aspects of security risk management.

2.2.1.4 Security Experts Perform Specialized Security Tasks

Security SMEs handle specialized security tasks, such as leading planning for security incident investigation and remediation.

The execution of some security duties requires specialized skills that other roles in the organization usually do not have. Organizations must plan to have access to this expertise, whether through full-time employees or through the integration of outsourced providers. The role definitions in this document identify the specialized security responsibilities and associated skills.

2.2.1.5 Teamwork on Security is Required, Recognized, and Rewarded

Security is a team sport, and all roles need to collaborate with each other for an effective approach.

Effective security decisions require considering a range of factors across business, technology, and security teams (e.g., threats, financial/operational impact) as well as effective execution across those same teams. Collaboration and well-defined roles, responsibilities, and decision rights are essential to enable teamwork for effective security risk management.

This document facilitates an integrated approach to security to meet these requirements and enables a modern asset-centric and business-aligned Zero Trust approach to security. For more information on Zero Trust security, refer to *Zero Trust Commandments* [C247].

2.2.2 Security Risk Outcomes

Decisions by anyone in an organization can increase organizational risk from security by enabling attackers to gain unauthorized access to business assets of the organization. *The change(s) in organizational risk resulting from decisions by anyone in an organization that can enable attackers to gain unauthorized access to business assets of the organization are **security risk outcomes**.*

These outcomes may enable an attack to succeed or increase the damage of an attack (up to or including material impact). For example, deprioritizing, deferring, or rejecting the application of a software security patch may result in security risk outcome of that system being compromised by an attacker. This can lead to further security risk outcomes, such as service downtime, breach of data confidentiality, integrity, and availability for regulated Personally Identifiable Information (PII) data and sensitive business data, and reputational harm to the organization; see Section 4.5 for more details.

Security risk outcomes can result from a single decision by a single person, but they often result from multiple decisions by multiple stakeholders.

¹ “Bang” in the context of the Security Roles and Glossary Standard refers to a Threat Event; refer to the *Security Roles and Glossary Standard – Part 1: Terms and Definitions* [S252].

Security risk is similar to the legal discipline where risk (liability) is created because of neglect, not by the act of an external actor (filing a lawsuit). Anyone who impacts the organization's security risk must have accountability for the security risk outcomes of their decisions.

Security risk outcomes are an intrinsic part of setting business priorities and goals/priorities for business lines, advising on legal and regulatory risk, managing health and performance of technical systems, etc. For organizational leadership and non-security roles, security accountabilities are inseparable from core responsibilities of the role. Security risk cannot be delegated or separated from roles that manage organizational risk, assets, or business lines.

The people who make decisions must feel directly accountable for their outcomes because people make higher-quality risk decisions when they worry they will have an uncomfortable discussion with their boss (*versus* having a vague sense that something bad might happen to someone else).

Tip: *Security risk outcomes can help to make security real and tangible for people.*

These should be documented and used to inform strategic security and technology roadmap, prioritization roadmaps items; for guiding funding and investment; and for the design and implementation of technical systems and controls. This helps reduce surprises for business and technology stakeholders, reduces inter-team friction, and supports adoption of an effective Zero Trust Strategy.

Business leaders must operate with a mindset that delegation of decision-making does not lead to abdication of responsibility and accountability. The role definitions in this document describe the correct delegation of accountability and responsibility for security, which should be reinforced with organizational governance and training.

2.2.2.1 *Blame versus Accountability*

Ensure that you are managing security accountability *as an accountability to perform a duty well over time* and not as an act of one-time blame to avoid changes. **Clear accountability is required to drive effective security risk management, but punitive measures should be explicitly reserved for intentional neglect of security duties.** This should be explicitly reinforced in the organization's governance model with decision rights, roles and responsibilities, and other technical, process, and human oversight.

Avoid a "blame culture" – blame is frequently counterproductive as it is often executed as a one-time act that assigns a culpable party without rigorous root cause analysis and changes that drive ongoing behavior and process improvement.

Poorly thought-out punitive measures can easily "backfire" and drive unintended counterproductive outcomes – if leaders seek to blame someone simply because a breach happened, this will undermine trust and collaboration required for effective risk management (often resulting in worse security risk outcomes).

Seeking someone to blame for a bad outcome (sometimes called a "witch hunt") will disrupt the trust and collaboration required for successful security risk management (e.g., nobody shares information or thoughts for fear of reprisal).

Tip: *Training, education, and governance are required.*

An absence of clarity and governance almost always leads to finger-pointing and a blame culture.

People cannot be held accountable for something they do not understand, so all team members must be educated on what they have to do, why it is important, and how to do it, enabling them to perform the accountabilities and responsibilities associated with their respective roles.

2.2.3 Security Risk Council and Individual Accountability

Because of the complexity and cross-cutting nature of security risk, business leaders require a forum and mechanism to work through security risk and establish/oversee management of cross-cutting security elements deeper in the organization. This may be provided through an existing governance mechanism or through a dedicated security risk council.

This mechanism must represent leaders for all business lines as well as key supporting functions including security, technology, legal, and HR.

Tip: *Always follow the “person in front of the television camera” rule to ensure risk is owned by the appropriate person.*

The “person in front of the television camera” is who will be in front of the television camera(s) explaining “what went wrong” if the security risk outcome occurs.

The security risk council should all consider the risk and provide input, but there must always be a single person who owns the risk and makes the final sign-off on risk acceptance and mitigation.

Because cybersecurity risk is like fire in a building where any small instance can spread rapidly and widely, most often, the Chief Executive Officer (CEO) or equivalent role must sign off on significant risks. If there is any disagreement among senior leaders, the sign-off must always escalate to CEO or equivalent role.

3 Role Definition Structure and Terminology

The role definitions in this document are structured consistently and use consistent terminology to minimize confusion. This chapter provides an overview of that content, which will be utilized through the various Parts 3.X of this document.

3.1 Key Information for Each Role

This document includes a dedicated section for each role that defines key aspects of security for each role including:

- Security job functions to be performed by the role (which may include accountabilities, responsibilities, or both), including a description of the risk of neglect if this job function is not performed correctly or at all (**What you do**)

The security job functions described in each role section are the “jobs to be done” for security and will be consistent for any organization. The method of assigning security job functions can vary across organizations, depending on organizational structure, culture, business priorities, financial constraints, etc. Security job functions may occupy a small percentage of a role’s time (common for non-security roles), or they may occupy almost all of the daily routine of a dedicated security role.

- Assets that each role is accountable for keeping secure and the role’s relationship to the assets (**What you secure**)
- Required security knowledge, skills, and abilities for the role (including relevant attack techniques for assets the role owns and manages) (**What you must know**)
- Relationship of the role to the security capabilities defined in the Zero Trust Reference Model [S232] (**How this relates to organizational security**)

This role information should guide your organization’s planning for assignment of security accountabilities and responsibilities, per role education, security policy, etc.

3.2 Role Terminology

This roles list and the way role terminology is used in this document are based on the Zero Trust Playbook series [Simos & Kumar, 2023].

A **discipline** is an area of study that often requires multiple roles and specializations to practice. Some examples of professional disciplines include security operations, architecture, application security, technical leadership, and business leadership.

A **role** is a collection of tasks (job functions) that someone performs to enable a capability on an ongoing basis. A role is often assigned to a single person, but multiple people may fulfill the role in a larger organization, or the same person may perform multiple roles in a smaller organization.

Security **job functions** represent security “jobs to be done”, which are sets of tasks required to achieve the overall outcome of effective security risk management. The overall workload for an organization and the number of people available to do it will greatly influence how many tasks people are assigned, how much of their time they can devote to each task, and how deeply they can specialize their knowledge and skills.

A **role specialization** level describes how generally or narrowly tasks are defined for a role. Highly generalized roles span many different tasks, while highly specialized roles focus narrowly on a few related tasks. Some roles will always be generalists (such as architects) to drive consistency across many teams in the organization, while others can become more specialized (such as engineers) as the organizational function matures and team size grows.

An **accountability** is the ownership of the impact and outcomes of a decision or action, including security impacts and outcomes. All roles make decisions and take actions during the course of their daily job duties, and all roles must be answerable for the results of their decisions and actions.

A **responsibility** is the obligation to fulfill duties and perform tasks to the best of your ability, often related to providing sound advice or executing tasks competently using subject matter expertise.

Responsibilities in security context can be security responsibilities, technology responsibilities, or responsibilities related to legal, financial, business operations, or other subject matters.

A **security responsibility** is the obligation to fulfill security duties and perform security tasks to the best of your ability. This often takes the form of executing security tasks competently and providing sound security advice tailored to the business context and decisions to be made.

Some examples include:

- Assessing security risk
- Investigating security incidents to understand a potential attack and coordinating remediation actions to remove adversary access to the organization's assets
- Recommending security mitigations

A **technology responsibility** is the obligation to fulfill security duties and perform security tasks to the best of your ability. Technology responsibilities relate to their expertise of technology and the design, configuration, and operation of the organization's technology estate.

Some examples include:

- Providing assessments of the feasibility of security decisions and guidance from decision-makers and security team members
- Providing solutions for the implementation of security decisions and guidance
- Implementing those solutions
- Providing ongoing operational support for technology solutions after implementation

4 Assigning and Managing Security Accountability and Responsibility

Security is a part of every role in an organization, but each role in the organization enables security risk management in a specific and unique way. This document assumes that no roles exist without any security responsibilities or accountability in an organization.

The security job functions for a role instantiates as either security risk accountability or as a responsibility. In any decision-making process, an accountable role owns:

- The final decisions and ultimate outcomes of those decisions
- Communication of a situation (from their perspective)

The responsible party(ies) in this process must:

- Provide clear and sound advice to the accountable decision-maker
- Execute any specialized tasks required by the final decision

4.1 Security Accountabilities, Responsibilities, and Job Functions

Accountability is an intrinsic part of owning a decision, but responsibilities may be assigned in different ways, depending on available resources and other factors.

4.1.1 Security Accountabilities

Security accountabilities are immovable.

Because security risk outcomes are an intrinsic part of managing organizational risk, assets, and business lines, the security accountability job functions must stay with those roles.

These role accountabilities cannot be delegated away. Delegating the security risk outcomes of business decisions to a security role or team (without the power to change the original decision) formalizes security as a powerless “scapegoat”, where their only real job is to accept blame when those decisions end badly.

Tip: *Misplaced accountability prevents effective security risk management.*

Many organizations make the mistake of delegating all security accountability to the security leader or team. This creates an incentive to misplace blame on the security team instead of on maturing security approaches and integrating security risk management into the organization.

This often happens when the security leader mistakenly accepts the accountability instead of clearly documenting the risk owned by the accountable party. This mistaken acceptance of accountability may be explicit or may be implicit, such as through neglect to document the risk, its source and owner, and other relevant attributes and analysis.

The principle that security accountabilities are immovable means that security accountabilities cannot be delegated away to specialists. This is similar to legal and other responsibilities:

- Legal liabilities cannot be delegated to lawyers
- Ignorance of the law is not acceptable as legal defense

Each job function in this document describes the risk of neglect to help organizations understand the consequences of accountable parties not performing their security duties. The impacts of this may include violation of fiduciary duty.

4.1.2 Security Responsibilities

Security responsibilities are flexible.

The assignment of security responsibility job functions may evolve over time. They may be moved or grouped differently (or the risk of not performing them may be accepted) based on the unique mission, risk, size, funding levels, available skills/talent, growth trajectory, etc. of your organization.

Note: Organizations with limited resources must often choose what to do *versus* what not to do. Each job function in this document describes the risk of neglect to guide these prioritization decisions based on your unique circumstances.

This document defines security job functions for all roles, including both security accountabilities and security responsibilities. These are assigned to roles with primary job responsibilities in security, non-security, and a small number of dual-purpose roles that are critical to both business enablement and security.

Business and technical leaders must become educated enough on security to faithfully execute their security accountabilities. The knowledge, skills, and abilities required for each role is defined as part of the role guidance in this document.

4.2 Types of Roles

Figure 3 visually depicts the range of different types of roles.

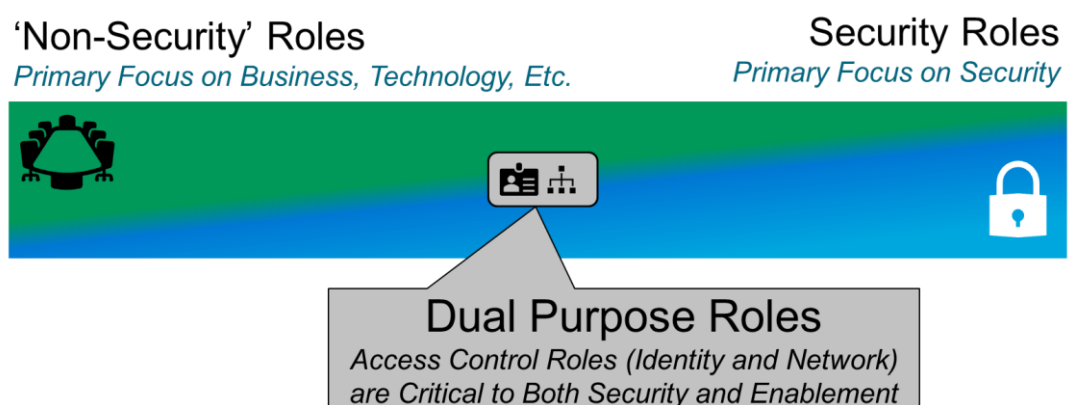


Figure 3: Types of Roles with Security Job Functions

Roles and their security job functions fit into one of three profiles:

1. Non-security roles with security accountabilities
2. Security roles with security accountabilities
3. Dual-purpose security and enablement roles

4.2.1 Non-Security Roles with Security Accountabilities

Business, technology, and other non-security roles have intrinsic security accountabilities that must be performed to ensure effective security risk management. These range from senior leadership roles who set up organizational accountability and policy/processes all the way to information workers and frontline workers who execute the core business processes of the organization every day.

Anyone who makes a security-impacting decision is accountable for the security risk outcomes of those decisions. Security risk can be created by individuals (e.g., clicking on a dangerous link, sharing sensitive data or passwords) or by business leaders (e.g., setting restrictive budgets that do not allow for security/safety controls) during their daily work.

In particular, technology team members have significant security accountabilities. Application architects and engineers have a responsibility to understand security concepts that apply to their discipline and apply them to ensure that the core systems in the organization are built to be secure. Enterprise, Business, and Solution Architects must ensure that the platforms, technologies, and system implementations use architectures and patterns that help meet the organization's security needs. Finally, technology leadership must ensure that the technology roadmap and its implementation take security concerns into account.

Figure 4² illustrates the non-security roles with security accountabilities.



Figure 4: Non-Security Roles with Security Accountabilities

² Refer to the note below Figure 2 for explanation of the star in Figure 4.

4.2.2 Security Roles with Security Responsibilities

Security roles with security responsibilities are primarily dedicated to security and must perform specialized security responsibilities. They must understand and integrate with the business and technology processes of the organization to ensure effective security risk management.

These responsibilities are primarily or fully dedicated to security tasks. The primary purpose of security roles is to support the core business mission with expert security work or advice/recommendations/guidance.

Figure 5 illustrates the security roles in an organization.



Figure 5: Security Roles with Security Responsibilities

4.2.3 Dual-Purpose Security and Enablement Roles

Dual-purpose security and enablement roles are critical to both business enablement and security risk management and have accountability to both. These roles perform a bridging function – they need to be in constant contact with non-security roles for enablement and with security roles for security risk reduction.

These roles are responsible for the architecture and systems that govern access to all of the organization's business assets. They are critical to enabling the business and ensuring that users are able to access the business assets required for business processes anywhere at any time. They are also critical to ensuring attackers cannot abuse those access systems to get access to business assets.

For instance, the roles that support access management are equally critical to business enablement and security risk management. Roles encompassing access management have a unique job of maintaining the digital front door and entrance lobby of the organization which must be simultaneously friendly, accessible, and secure. Access control is the front door and lobby of a digital business. This is a very special discipline because everyone goes through this digital front door to get their job done – it shapes their experience, but it must be secure. Criminals want to get access to the same resources so they attempt to use the same mechanisms; this must also be secure.

Figure 6 illustrates the dual-purpose roles in an organization.

Security accountabilities & responsibilities across an organization



Figure 6: Dual-Purpose Security and Enablement Roles

4.3 Collaboration between Security and Non-Security Roles

Healthy collaboration between security roles and non-security roles must exist.

Effective security requires collaboration across these different role profiles – security-impacting business decisions are both high-impact and complex, requiring:

1. The appropriate decision-makers to be held accountable for decisions
2. The responsible roles (security roles and dual-purpose roles) to provide the context to enable informed decisions with expert advice, education, policy, and other resources

Guiding Principle:

Effective security requires both accountability and collaboration.

The accountability model should be clear and specific to ensure the correct people are making impactful decisions, but it should be executed in a collaborative environment where people work together on complex challenges. This should be a high-trust environment where people can share freely to enable creative thinking required for the complex, challenging, and continuously changing nature of security risk.

Team members must be able to voice opinions without fear of reprimand.

4.3.1 Duties of Security Decision-Making

Security decision-making imposes certain duties on both decision-makers and SMEs. While there may be some nuance and variation, the duties for security decisions are divided between accountable decision-makers who own decisions spanning many risks and opportunities (*duty to decide*) and the SMEs who have a duty to provide sound advice and context (*duty to advise*).

In a proactive, strategic context, security risk outcomes determine risk and drive prioritization. Collaboration among security, technology, and non-security roles is essential to ensure that the business plans for and appropriately funds security, that technology selections and implementations are made keeping in mind security requirements, and that appropriate decisions are taken. When business, technology, and security stakeholders do not work together, this results in negative outcomes for all three (increased security risk, reduced productivity, increased technology rework and wasted effort, and more).

4.3.1.1 *Duty to Decide (Accountable Decision-Maker/Party)*

Accountable decision-makers have an obligation to make informed decisions that balance and prioritize across the full range of associated opportunities and risks associated with that decision. These decision-makers must make the best possible decisions on behalf of the organization and should seek tailored advice and recommendations from security and other experts to do so. These roles often also monitor and oversee execution of higher impact decisions and actions. Accountable decision-makers are typically CEOs or other business leaders who have been delegated full accountability for part of the organization.

4.3.1.2 *Duty to Advise (Responsible SME/Party)*

SMEs for security and other topics have an obligation to provide sound advice to accountable decision-makers to the best of their abilities. This advice is based on their specialized expertise and knowledge, but it must be tailored to the context of the situation and organization. These roles also often have a duty to competently implement and execute those decisions. Responsible SMEs may be security team members, lawyers, HR professionals, other specialized roles, or other managers and individual contributors with specific expertise.

Guiding Principle:

All roles have a duty to execute security faithfully.

All roles in an organization have security duties that represent legal, fiduciary, and moral commitments. Whether a role is accountable for security risk outcomes of their decisions or responsible for expert advice and execution, every role has an obligation to execute those duties fully, effectively, competently, and honestly (including continuous learning and improvement).

For example, a business leader should never pressure a responsible SME into providing incomplete or inaccurate security risk assessments to support a predetermined business outcome. Organizational culture should support faithful execution and organizational governance structures should detect and remediate any failures in the accountability model. This example may create a violation of fiduciary duty in many jurisdictions.

4.4 Relationships between Accountable and Responsible Parties

Collaboration between accountable and responsible parties is critical. Making good security risk decisions requires a healthy and collaborative relationship where accountable decision-makers and security SMEs can safely share ideas and challenge incorrect assumptions.

Guiding Principle:

A collaborative relationship between accountable and responsible parties is essential.

Figure 7 illustrates responsibilities and communications in a healthy and collaborative relationship.

Accountability and Responsibility

A Healthy Collaboration When Done Right



Figure 7: Relationship between Accountable and Responsible Parties

An accountable role owns communication of a situation (from their perspective) and the final decisions and ultimate outcomes of those decisions. Responsible parties must provide clear and sound advice to the accountable decision-maker and execute any specialized tasks required by the final decision.

This must be a collaborative process to blend different perspectives and expertise and to reach the best decision in complex situation. These interactions should be regular and frequent to enable agility while handling complex and continuously changing risks. The exact cadence will depend on many factors in the organization and the individuals involved, and a minimum interaction frequency may be defined by policy. This collaborative process should be defined in the governance framework and operating model of the organization.

4.4.1 Factors Driving and Determining the Collaborative Process

Many factors drive continuous changes that can affect situations, business goals, and what the best expert advice would be, including market changes, technology capabilities, internal initiatives, and discovery of hidden assumptions.

The components of the interaction between accountable and responsible parties should include:

- **“Situation and Goals”** – the accountable role must provide clear goals and constraints of situations to guide the SME(s) on the needs and desired outcomes
This applies for normal operations and special situations like proposed business initiative(s) or crises.
- **“Expert Advice”** – responsible parties must provide expert advice to the accountable parties to inform their decisions
This is typically composed of identifying available options and which ones are recommended by the expert based on their expertise and knowledge of the situation.
The recommendation(s) and options should be based on evidence and defensible reasoning (which may or may not need to be documented depending on the situation).
This may be provided by external parties such as managed services or consulting services in some situations.
- **“Informed Decisions”** – the accountable party must make the final decision based on the advice and data available
This should consider all risks and opportunities from multiple responsible parties and any other context the decision-maker has access to.
Ideally, this is a collaborative process where multiple parties share their knowledge and expertise to jointly identify the best courses of action. Accountable parties should also share their reasoning and empower others to make similar decisions more quickly in the future (if not prevented by sensitivity of the decision). Sometimes this may be captured in policy, educational material, or other documentation to make future decisions more efficiently.
- **“Execution”** – the responsible party(ies) often must execute the decision by the accountable party
They should share updates on execution status, any learnings or insights they discover, and request allocation of resources from the accountable needed to execute.

4.4.2 Dealing with Complexity and Fluidity in the Collaborative Process

The security situations are often complex and fluid. For an effective collaborative process, some fundamental tenets need to be established:

1. Assumptions must be identified, documented, and shared
2. Policy and education guide decisions
3. A single person may act in both roles in some complex situations

4.4.2.1 *Assumptions must be Identified, Documented, and Shared*

Throughout this process, it is imperative to recognize that different career paths develop important and unique assumptions specific to that discipline, which can be implicit or not obvious to others.

Clear communications and good decisions require discovering and sharing those hidden assumptions as context. These should be documented to accelerate the process of sharing and fusing context from multiple disciplines, which can take many forms (e.g., a strategy document, architecture document, assumptions in specification). For example, the way that business leaders automatically think about risk and how much risk is acceptable is often different than technology or security professionals, which can cause miscommunication issues.

4.4.2.2 *Policy and Education Guide Decisions*

Many similar situations may come up in the future, and organizations should create policy and education to quickly enable people to consistently make good decisions in the future. Security changes frequently, so policy and education must be governed as continuously updated capabilities – this helps ensure that all roles can adapt to changing goals and external factors. It is also critical to document the original (and updated) reasoning for policy to inform future revisions (i.e., so people can evaluate whether the same driving factors are still true later).

4.4.2.3 *A Single Person May Act in Both Roles in Some Complex Situations*

Some complex or high impact situations rely on a chain of analysis and actions by many responsible parties across the organization. Sometimes, people may be accountable for developing advice on one aspect of a larger decision but only responsible for giving that advice to the ultimate accountable party (often a senior organization leader). For example, a technical leader may act as the accountable party and gather technical options and recommendations from their team, which they further contextualize and present to an organizational leader as higher-level choices and recommendation(s) along with other business alternatives.

4.5 General Security Impacts

Security incidents can have a significant negative business or mission impact on the organization, which results in a loss for the organization. The “risk of neglect” described in each role section in Part 3.X describes how not performing one of the security duties contributes to increased likelihood and impact of a loss.

Note: The impacts and likelihood vary by a number of factors, including the motivation and actions taken by an insider or external attacker, how well prepared the organization is, and how well the organization responds to the incident. The tolerance and capacity for loss also varies by organization – some organizations will be able to withstand much larger losses that would result in insolvency for others.

The types of negative business impact from a security incident are as complex and varied as the organization itself. Some only have simple direct impacts (like the cost of a technical recovery, a ransomware payment, or lost revenue), while others are much more complex and nuanced. Some incidents result in data loss/corruption and product tainting that may cause injuries or death, affect the organization’s core mission and revenue, causes reputational damage, incur fines and post incident litigation, and deny the organization’s ability to participate in regulated markets.

Extortion methods also extend the damage beyond the organizational boundaries by threatening executives and their family members, the organization’s customers and suppliers, etc.

This is a list of quantifiable organizational losses derived from The Open Group Standard for Risk Taxonomy (O-RT), Version 3.1, [C251] §4.4.1:

- **Productivity** – direct losses associated with the reduction in an organization’s ability to generate its primary value proposition (e.g., income, goods, services); it may also include costs associated with personnel who are unable to perform their duties but who continue to collect their paycheck (e.g., a call center’s phone lines are down, but personnel continue to be paid); it accounts for the loss of revenue due to operational outages and discontinuation (e.g., revenue lost when a retail website is unavailable due to a system

outage); and it includes costs associated with the impaired productivity of personnel (e.g., increased costs from switching from automated to manual methods)

— Lost revenue is not delayed revenue; for example, when a retail website goes down some proportion of its customers may wait to perform their transactions rather than use a different retailer – the sales and marketing departments in most organizations will have reliable data to inform these estimates

- **Response** – direct expenditures associated with managing a Loss Event (e.g., internal or external person-hours, logistical expenses, legal defense, public relations expenses)
- **Replacement** – direct expenditures associated with replacing an Asset; typically represented as the expense associated with replacing lost or damaged Assets (e.g., rebuilding a facility, purchasing a replacement laptop, replacing a terminated employee, covering the losses experienced by fraud)
- **Fines and judgments** – direct expenditures associated with legal or regulatory actions levied against an organization, including settlements and bail for any organization members who are arrested
- **Competitive advantage** – future estimated business losses associated with a diminished competitive position, specifically associated with Assets that provide competitive differentiation (e.g., lower production cost, higher quality, advanced capabilities) between the organization and its competition
 - Within the commercial world, examples would include operational efficiencies, trade secrets, merger and acquisition plans, etc.
 - Outside the commercial world, examples would include military secrets, secret alliances, etc.
- **Reputation** – future estimated business losses associated with an external stakeholder's perception that an organization's value proposition is diminished and/or that the organization represents liability to the stakeholder; this accounts for any reduction in revenue due to lost market share and typically materializes as reduced market share (for commercial organizations), reduced stock price (for publicly traded companies), reduced willingness to cooperate in joint ventures, or an increased cost of capital

Some of these factors can amplify other factors, such as a loss of reputation leading to revenue loss (or revenue losses impacting the organization's reputation). Organizations often experience increased impact based on other factors like being unprepared, being forced to recover business services using low-quality attacker-provided tooling, understaffed security and technology functions, attacker errors, or extortion pressure, and technical errors by threat actors or the organization (losing keys, losing data, miscommunications, etc.).

5 Adapting and Adopting Role Guidance

Adapting role guidance means determining how to adjust it for your organization's specific needs and nuances. For example, it could mean renaming an existing role in the organization or assigning responsibilities to an existing role.

Adopting role guidance addresses an organization's decision to use this document. When adopting this document, the organization makes a conscious decision to use and adapt it to the organization's nuances.

5.1 Adapting Role Guidance

In adapting role guidance, there are several critical aspects to consider:

1. Select and map which roles apply to your organization (look at both the roles and their job functions to map them to your organization)
2. Ensure all accountabilities are assigned to someone in the organization (even if it is a lot for one role)
3. Determine how to choose what work will be done and what will not be done for responsibilities (e.g., the organization does not have enough funding or ability to hire the ideal staffing levels and must prioritize)

5.2 Adopting Role Guidance

Implementing this document can be complex for organizations that have treated security tasks as exclusively the security team's job.

If non-security roles are unfamiliar with what decisions have a cybersecurity impact or the possible security implications of their decisions, organizational leadership must prioritize clear accountability/incentive structures, policy, and education early to increase collaboration and knowledge sharing between security and non-security team members.

Plan on adoption to evolve and be executed as a part of an overarching security roadmap.

5.2.1 Adoption Strategy for Non-Security Roles

Structure security as a support and enablement function to the business and to other support functions, similar to the way you structure technology, legal, finance, and HR. Ensure that accountable parties have both the accountability and the support they need to succeed in their security duties.

Figure 8 illustrates how to structure security as a business support function.

Security is a Business Support Function

Like Legal, Human Resources, Finance, Technology, and Others

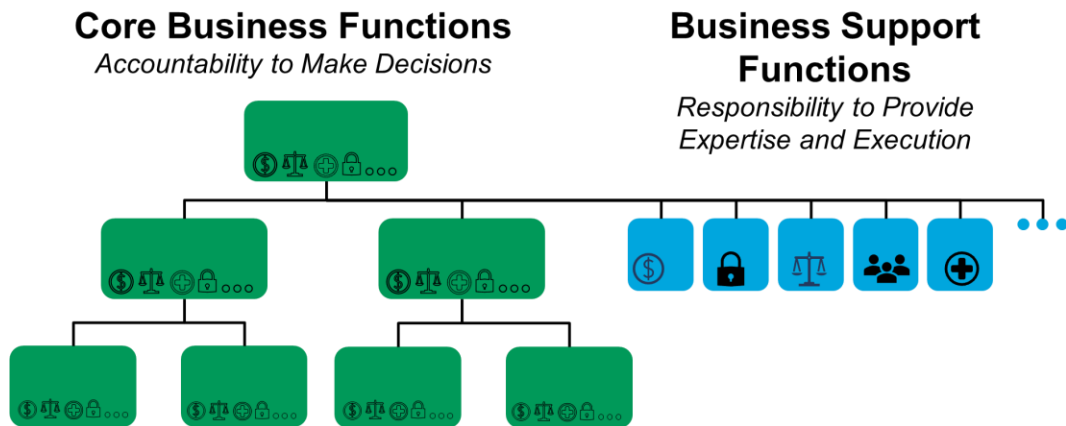


Figure 8: Core Business Functions *versus* Business Support Functions

For roles where security is not the primary responsibility, ensure security accountabilities are mandatory additions for these roles in an organization (regardless of whether/how they are staffed). The organization cannot successfully manage security risk if the decision-makers who make decisions that affect security risk are not held accountable for those decisions and all impacts of it, including legal, HR, and security.

Organizations must position security as a business support function that provides specialized expertise to the business units throughout the organization (and other business support functions). Security leaders should be positioned as experts to aid business leaders who are accountable for the implications/outcomes of business decisions across financial, legal, security, and other dimensions. Security teams should be integrated into business and technical processes as experts who provide expert advice, guidance, and support.

Technology also must incorporate security into its mandatory responsibilities. Execution of organizational policy in a digital enterprise requires the use of technology personnel. Training, having a voice in both business and security strategy (and *vice versa*), incorporating security into the technology roadmap, and execution are all key for successful security implementation.

5.2.2 Adoption Strategy for Security Roles (Responsibilities)

Security roles should actively engage throughout the organization to provide advice and support that enables business success. Security should be responsible for both enabling positive impact of the business mission and revenue as well as managing negative impact of risk management.

Security advice must be in the context of the organization – security roles must provide subject matter expertise tailored to the organizational operating model, compliance requirements, technical estate, and resource/funding and business constraints.

Security roles must be proactive – security must engage with business and technology teams to proactively understand the business, identify security risk, and document it clearly in business

terms (including quantifying risk and using the accepted risk management framework of the organization³).

Responsibilities and staffing will vary by organization depending on the size, funding level, regulatory compliance, etc. The organization must align its security investment strategy to risk tolerance and business priorities. The organization has some discretion on how to fund this and how to structure these roles, within the bounds of a well-designed sustainable system, and while ensuring the organization is providing appropriate due care and due diligence.

Note: Security responsibilities may also be assigned differently within specific business units. For example, one business unit in an organization may invest heavily into software security engineering because they create a lot of software with high business impact compared to other business units that do not share this requirement.

Organizations do not always need a dedicated person or team for each aspect of security, but someone must be responsible for each aspect of security, or the risk of a missing risk management element must be accepted by the organizational leadership.

Figure 9 illustrates the ways that organizations can assign security responsibilities.

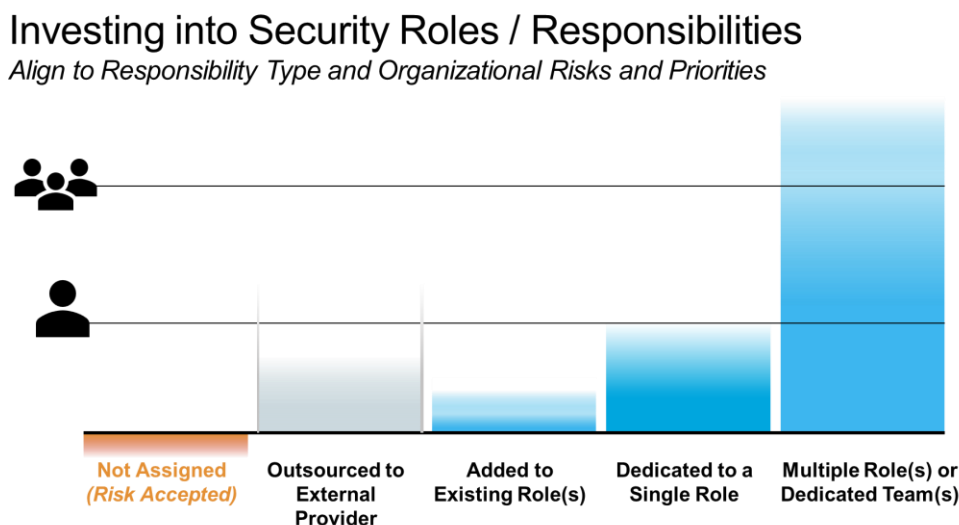


Figure 9: Assigning Security Responsibilities

Organizations can choose to invest how they will assign resources to each security responsibility on a level of 0 to 4.

5.2.2.1 Level 0: Not Assigned (Risk Accepted)

Organizations can explicitly choose not to assign a set of security responsibilities (temporarily or permanently), which requires accepting the risk/implications of missing this responsibility in the organization. This is described in the risk of neglect for each job function in each role.

Smaller organizations have significant budgetary constraints and often must make this decision. Any choice not to assign these security responsibilities must be done with due consideration of

³ If the organization does not have an accepted risk management framework, security personnel should work with business leaders to identify and adopt one.

the risks the organization assumes by deferring or forgoing until a future date or event (such as the growth of the organization or revenue/budget).

5.2.2.2 *Level 1: Outsourced to External Provider (Partially or Fully)*

Security responsibilities may be assigned to an outsourced provider (partially or fully). Organizations may bring in outside experts to perform a task instead of it being performed by the organization, often to gain access to rare skills or mature processes without having to develop it themselves. This may follow many different models with various relative tradeoffs and advantages and disadvantages.

Examples include outsourcing security operations or security operations triage functions.

5.2.2.3 *Level 2: Add to Existing Role(s)*

Organizations may assign security responsibilities to existing role(s) as additional job responsibilities. This results in a combined role (someone who “wears multiple hats”).

Some organizations may also choose to merge the roles to drive closer coordination required by their business model (e.g., Chief Security/Strategy Officer (CSO) and Chief Information Security Officer (CISO); Chief Product Officer (CPO) and data officer; Chief Technology Officer (CTO) and Chief Digital Officer (CDO); automation as a core skill on multiple engineering teams). Some organizations with smaller budget/teams may have a single security operations analyst role that does both triage and investigation or have a single Chief Digital Officer that performs CDO and CTO roles. Smaller organizations may have a single Technology Director leading for both the forward-looking and the current-state technology. Some organizations may have the same roles perform both engineering and operations, including some generalists doing this across all technology specialization.

5.2.2.4 *Level 3: Dedicated Role*

Organizations may assign security responsibilities as a dedicated role to a single person. This allows for deeper specialization and greater competency, but it also creates single-point-of-failure risk, especially if institutional knowledge is not documented or automated. To avoid this, the organization must ensure role continuity via documentation, automation, cross training, etc.; this applies to all lower levels, too.

5.2.2.5 *Level 4: Multiple Role(s) or Dedicated Team(s)*

Security responsibilities may be assigned to multiple people or a dedicated team of people. Larger organizations and highly targeted organizations may require more people to handle their increased workload (driven by more resources to protect, more attacks, more internal organizations to coordinate with, etc.). This typically affects specific functions like security operations, engineering, architecture, compliance, or governance.

Acronyms and Abbreviations

CDO	Chief Digital Officer
CEO	Chief Executive Officer
CISO	Chief Information Security Officer
CPO	Chief Product Officer
CSO	Chief Security/Strategy Officer
CTO	Chief Technology Officer
HR	Human Resources
PII	Personally Identifiable Information
SME	Subject Matter Expert

Index

accountabilities.....	5	non-security roles.....	22
accountability	11	policy decisions.....	20
accountability model.....	16	productivity.....	20
accountable decision-makers ...	17	quantifiable organizational losses	20
accountable role.....	18	replacement.....	21
adapting role guidance	22	reputation.....	21
adopting role guidance.....	22	response	21
blame culture.....	8	responsibilities	5
collaboration.....	16	responsibility.....	11
competitive advantage	21	responsible party	18
delegation.....	8	risk of neglect.....	20
discipline.....	10	role	10
duty to advise	17	role specialization	11
duty to decide.....	17	security decision-making.....	17
education policy	20	security incident	20
execution.....	19	security job functions	10
expert advice	19	security responsibility.....	11
extortion methods.....	20	security risk council	9
finances and judgments	21	situations.....	19
goals.....	19	Subject Matter Expert.....	6
informed decisions.....	19	technology responsibility.....	11
mission impact	20	Zero Trust Strategy	8
negative business.....	20		